

Vulnerability Management: 4 Steps to Successful Remediation

What is Vulnerability Management?

Vulnerability management is the practice of identifying, analyzing, and remediating hardware or software defects that attackers can exploit to carry out cyber attacks.

A vulnerability is a security weakness in a system that might enable an attacker to gain unauthorized access to resources, steal sensitive data, disrupt business operations or do damage to an organization's systems. Key elements of vulnerability management include:

- Detection methods such as vulnerability scanning and penetration testing.
- [Vulnerability assessment](#) and prioritization using threat intelligence, automated analysis, and manual investigation.
- Remediation, which might be performed manually by IT and security teams, or automatically by vulnerability management, patch management, or security posture management systems.

Due to the evolving nature of threats, vulnerability management must be continuous, iterative, and must be informed by up-to-date threat intelligence sources that provide information about the latest threats and attack techniques.

How Are Vulnerabilities Defined?

Vulnerabilities can be defined in several ways, including:

The security content automation protocol (SCAP) standard

Vulnerability management is an open, standard-based effort that involves using the SCAP standard. The National Institute of Standards and Technology (NIST) developed SCAP to help facilitate a standardized approach to defining vulnerabilities.

SCAP defines vulnerabilities according to several categories, such as the common vulnerabilities and exposures (CVE) definitions, which define each vulnerability by the

attacks it can cause. It also includes the common configuration enumeration (CCE) list of system security configuration issues for configuration guidance.

The SCAP standard defines common platform enumerations (CPEs) that offer standardized methods for identifying and describing classes of operating systems, devices, and applications within an environment. CPEs help describe what a specific CCE or CVE applies to.

Another SCAP contribution is the common vulnerability scoring system (CVSS), which helps assign severity scores to defined vulnerabilities. It helps prioritize remediation efforts according to severity levels.

Public definitions

You can use public sources of vulnerability definitions, including the National Vulnerability Database (NVD) and Microsoft security updates. You can also access private vulnerability databases offered by security vendors via a paid subscription.

Security benchmarks

Security configuration benchmarks help establish how to configure operating systems and applications securely. The Center for Internet Security (CIS) offers a broad range of updated configuration benchmarks, which you can use to assess and remediate configuration-based vulnerabilities.

A 4-Step Vulnerability Management Process

1. Identification

A vulnerability management system continuously scans an environment against one or more databases of known vulnerabilities, with the objective of identifying vulnerable assets. Different types of vulnerability scanners might be deployed, depending on the stage of the product lifecycle and the type of environment (on-premises, cloud, or hybrid).

In development stages, it is most common to use white-box testing technologies like static application security testing (SAST), which examines source code for security issues. In testing and staging environments, it is common to perform black-box testing using tools like dynamic application security testing (DAST), which execute the application and test it while it is running.

In production, runtime protection technologies such as runtime application self protection (RASP) can identify vulnerabilities as they occur.

Related content: Read our guide to [vulnerability scanning](#)

2. Prioritization

In larger organizations, there might be thousands of managed assets with multiple vulnerabilities identified for each asset. It is usually not feasible to remediate all vulnerabilities, and it is also not necessary, because many vulnerabilities are not severe or not really exploitable by attackers.

To optimize remediation efforts, you should prioritize vulnerabilities based on the risk they pose to your organization. Vulnerability databases typically assign technical severity scores, and advanced vulnerability management solutions can fine-tune these scores to reflect the real business impact or actual chance of exploitation in specific managed assets.

3. Remediation

The responsibility of a vulnerability management system does not end with identifying and prioritizing security flaws—it should also determine the ideal action to take to address these vulnerabilities. This can include applying patches, reconfiguring network settings, changing access control settings, and removing unused applications.

At this stage, IT and security teams must balance the need for quick resolution with the cost of a fix and its potential impact on system uptime and productivity. A vulnerability management system should provide a means to track which vulnerabilities have been addressed, which are still pending resolution, and which can be safely ignored.

Related content: Read our guide to [vulnerability remediation](#)

4. Verification and Reporting

Once a set of actions is identified, IT staff implement the fix, or in some cases, it is applied automatically by the vulnerability management system or other integrated systems. The vulnerability management system should then verify that the fix is implemented correctly and report if anything is left to fix.

In reality, many remediations are not easy to implement. Systems have complex interdependencies, and in some cases, the risk of interrupting mission-critical systems might outweigh the need for a security fix. Whatever the decision made by those responsible, there should be full visibility to IT and security leadership if any fixes are purposely delayed.

To support this visibility, a vulnerability management solution should include reporting capabilities to check the current status of systems and the progress of vulnerability fixes.

Tips for Successful Vulnerability Management

Automate Your Process

In modern enterprise environments, to be effective, vulnerability scanning must be automated and integrated into every stage of the development lifecycle. There are multiple technologies that can help achieve this, including static application security testing (SAST), dynamic application security testing (DAST), interactive application security testing (IAST), and runtime application self protection (RASP).

In a cloud environment, solutions like cloud security posture management (CSPM) and cloud workload protection platforms (CWPP) can continuously verify secure configuration of an organization's assets.

Leverage Penetration Testing

Penetration testing is a cybersecurity technique used by organizations to identify, test, and highlight vulnerabilities in their security mechanisms.

There are several types of penetration tests. A test might attempt to identify vulnerable systems, identify attack vectors that could impact a specific system, or actually attempt a breach using one or more of these attack vectors. Each of these tests can provide valuable information that helps an organization remediate its systems.

Penetration test results have two benefits—they demonstrate the strength of an organization's current security process, and reveal critical security weaknesses that require priority remediation. Unlike automated vulnerability scans, a penetration test can prove the potential business impact of vulnerabilities, and identify weaknesses that automated tests are unable to detect.

Penetration testing is best performed by a third party to maintain objectivity during testing and analysis reporting. Penetration testers should have experience in ethical hacking techniques and should be able to script and fine-tune test setups according to the specific environment being tested.

Beyond Automation and Penetration Testing

While automated security testing and penetration testing are valuable, they are not enough. Both automated tools and penetration testers can discover important vulnerabilities that can improve your security posture. But you cannot be sure that they provide a holistic review of your attack surfaces.

A holistic approach is needed to monitor organizational systems for vulnerabilities, combining automated scanning with human expertise to ensure all major vulnerabilities are on the radar, prioritized and handled properly.

Vulnerability Management with HackerOne

The HackerOne platform is designed to give organizations both broad and deep visibility into their vulnerability landscape. The platform provides organizations with access to thousands of skilled pentesters and ethical hackers, rated by past performance and technical skills. The platform provides:

- Workflow and reporting mechanism to visualize and communicate findings
- System of knowledge sharing for new and unique vulnerability categories and techniques
- Findings capture and tracking in a vulnerability database
- Integrations with vulnerability management systems, DevOps tools and ticketing systems

HackerOne brings a unique combination of software and human expertise to vulnerability management. Specifically, HackerOne leverages security experts - also known as ethical hackers or security researchers - who apply their knowledge of applications and infrastructure to find vulnerabilities automated scanners miss.

Most often, HackerOne is used in combination with vulnerability scanners or vulnerability management tools to enhance effectiveness. Typically, scanners are used first to capture the bulk of known vulnerabilities. HackerOne solves three common problems faced in vulnerability management:

- Finding new or unknown vulnerabilities that scanners are blind to. These are often the vectors that cybercriminals favor.
- Triaging vulnerabilities, removing false positives and patching exploits before they are exposed while prioritizing critical ones first
- Providing human bandwidth to manage the high volume of reported vulnerabilities, including retesting against vulnerabilities that have been fixed.

HackerOne security testing includes pentesting which is performed by a dedicated team of fully vetted ethical hackers with specific skills. The HackerOne platform supports agility and collaboration so customers can see results real-time vs. waiting for a completed report. This provides insights to vulnerabilities early and accelerates the remediation process.

Learn more about HackerOne's [Vulnerability Management solutions](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker?

